



FUTURE INTERNS

VULNERABILITY ASSESSMENT REPORT

Security assessment identifying
vulnerabilities, risks, and remediation
recommendations.

MAY 2026

Prepared by
SWAMANTAK ROY

Approved by
Future Intern

Executive Summary

- This report presents the results of a read-only vulnerability assessment conducted on the OWASP Juice Shop demo application.
- The purpose of this assessment was to identify common security weaknesses that may impact the confidentiality, integrity, and availability of the application.
- The assessment was performed using passive and non-intrusive techniques only.
- No exploitation, brute force attacks, denial-of-service activities, or unauthorized access attempts were conducted during collection of data.
- The review of the collected data identified multiple security concerns, including -
 - exposure of sensitive files
 - publicly accessible backup files
 - missing security headers
 - insecure cookie configurations
 - information disclosure issues.
- The findings in this report are categorized using Low, Medium, and High risk levels based on their potential impact and likelihood of misuse.

Scope & Methodology

Scope:

The assessment was conducted under a strictly read-only and ethical scope.

Allowed Activities:

- Public-facing page analysis
- Passive scanning
- Header inspection
- Configuration review
- Browser-based inspection

Restricted Activities:

- Exploitation attempts
- Authentication bypass
- Brute force attacks
- Denial-of-Service attacks
- Any activity capable of harming the target system

Tools Used:

- Nmap
- OWASP ZAP (Passive Scan)
- Firefox Developer Edition DevTools
- Canva

Assessment Methodology

The following methodology was followed during the assessment:

1. Identification of publicly exposed services
2. Passive inspection of application responses
3. Security header analysis
4. Review of cookie configurations
5. Identification of publicly accessible sensitive resources
6. Documentation and risk classification of findings

Risk Rating Criteria

Risk LevelDescription:

- High:

Serious security weakness that may expose sensitive information or significantly impact the application.

- Medium:

Moderate security issue that could increase risk if combined with other weaknesses.

- Low:

Minor issue with limited direct impact but should still be addressed.

Summary of Findings

No.	Vulnerability	Risk Level
1	Sensitive Files Exposed via /ftp Directory	High
2	Backup Files Publicly Accessible	High
3	Suspicious Files in Public Directory	High
4	Missing Content Security Policy (CSP)	Medium
5	Absence of HTTPS	Medium
6	Missing HSTS	Medium
7	Insecure Cookie Configuration	Medium
8	Information Disclosure via File Structure	Medium
9	Exposure of Application Dependencies	Medium
10	Open Port 3000	Low
11	robots.txt & sitemap.xml Accessible	Low

Detailed Findings

1. Sensitive Files Exposed via /ftp Directory:

Risk Level: High

Explanation:

The application allows public access to internal files stored in an exposed /ftp directory.

Why It Matters:

These files may contain sensitive business information, internal documentation, or application-related data that should not be publicly available.

Business Impact:

Public exposure of sensitive files may increase the risk of data leakage and unauthorized information disclosure.

Remediation:

- Remove sensitive files from public directories
- Restrict access using proper server configuration
- Regularly audit publicly accessible directories

2. Backup Files Publicly Accessible:

Risk Level: High

Explanation:

Backup files with extensions such as .bak are accessible directly through the browser.

Why It Matters:

Backup files may contain confidential information including application source code, credentials, or internal configurations.

Business Impact:

Exposure of backup files may lead to unauthorized access to sensitive operational information.

Remediation:

- Store backup files outside publicly accessible directories
- Restrict access using server-side access rules
- Regularly review exposed files on production systems

Detailed Findings

3. Suspicious Files in Public Directory:

Risk Level: High

Explanation:

Files resembling malware or suspicious executable content are publicly accessible within the application.

Why It Matters:

Such files may negatively affect user trust and could potentially be misused for malicious purposes.

Business Impact:

Public availability of suspicious files may damage organizational reputation and increase perceived security risk.

Remediation:

- Remove suspicious files immediately
- Conduct regular file integrity reviews
- Restrict unauthorized file uploads

4. Missing Content Security Policy (CSP):

Risk Level: Medium

Explanation:

The application does not implement a Content Security Policy (CSP) header.

Why It Matters:

Without CSP protection, malicious scripts may execute more easily within the browser environment.

Business Impact:

The absence of CSP may increase exposure to browser-based attacks affecting users of the application.

Remediation:

- Implement a Content Security Policy header
- Restrict execution of untrusted external scripts
- Define approved content sources

Detailed Findings

5. Absence of HTTPS:

Risk Level: Medium

Explanation:

The application uses HTTP instead of secure HTTPS communication.

Why It Matters:

Data transmitted over HTTP may be intercepted or modified during transmission.

Business Impact:

Sensitive user information may be exposed while communicating with the application.

Remediation:

- Enable HTTPS using SSL/TLS certificates
- Redirect all HTTP traffic to HTTPS
- Enforce secure communication across the application

6. Missing HSTS:

Risk Level: Medium

Explanation:

The application does not implement HTTP Strict Transport Security (HSTS).

Why It Matters:

Users may unknowingly access the application using insecure connections.

Business Impact:

The lack of HSTS may increase the risk of insecure communication and session exposure.

Remediation:

- Enable the HSTS security header
- Configure browsers to enforce secure connections
- Apply secure transport policies consistently

Detailed Findings

7. Insecure Cookie Configuration:

Risk Level: Medium

Explanation:

Application cookies are missing important security attributes such as Secure and "HttpOnly".

Why It Matters:

Cookies may become accessible to malicious scripts or transmitted over insecure channels.

Business Impact:

Weak cookie protection may increase the risk of unauthorized session access.

Remediation

- Enable the Secure flag
- Enable the HttpOnly flag
- Review session management practices

8. Information Disclosure via File Structure:

Risk Level: Medium

Explanation:

Internal directories such as "/node_modules" are publicly visible.

Why It Matters:

Visible directory structures may help attackers understand the underlying application architecture.

Business Impact:

Information disclosure may simplify reconnaissance activities against the application.

Remediation:

- Disable directory listing
- Restrict access to internal directories
- Expose only required public resources

Detailed Findings

9. Exposure of Application Dependencies:

Risk Level: Medium

Explanation:

Internal libraries and framework components are publicly accessible.

Why It Matters:

Attackers may identify outdated dependencies and known vulnerable components.

Business Impact:

Outdated or exposed dependencies may increase the risk of targeted attacks.

Remediation:

- Restrict access to dependency directories
- Regularly update application libraries
- Remove unnecessary public exposure of backend components

10. Open Port 3000:

Risk Level: Low

Explanation:

The application service is accessible through open Port 3000.

Why It Matters:

Open ports increase external visibility of running services.

Business Impact:

Unnecessary exposure of services may increase the application's attack surface.

Remediation:

- Restrict access using firewall rules
- Use reverse proxy protection in production environments
- Limit externally exposed services

11. robots.txt & sitemap.xml Accessible:

Risk Level: Low

Explanation:

The robots.txt and sitemap.xml files are publicly accessible.

Why It Matters:

These files may reveal hidden directories or application endpoints.

Business Impact:

Public disclosure of internal paths may support reconnaissance activities.

Remediation:

- Avoid listing sensitive directories
- Review publicly exposed paths regularly
- Limit unnecessary information disclosure

Positive Security Observations:

Partial Security Headers Implemented,

Observation:

The application includes the following security headers:

- X-Content-Type-Options
- X-Frame-Options

Why It Matters:

These headers provide protection against common browser-based attacks such as clickjacking and MIME-type confusion.

Comment:

The presence of these headers demonstrates partial implementation of security best practices.

Nmap Scan Result Screenshots:

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 20:20 +0530
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0010s latency).
Other addresses for localhost (not scanned): ::1

PORT      STATE SERVICE VERSION
3000/tcp  open  ppp?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3000-
TCP:V=7.99%I=7%D=4/27%Time=69EF77B6%P=i686-pc-windows-windows%
SF:r(GetRequest,1C48,"HTTP/1.1\x20200\x20OK\r\nAccess-Control-Allow-Origi
-Control-Allow-Orig
SF:n:\x20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20S
SF:AMEORIGIL ↓ iFeature-
Policy:\x20payment\x20'self\r\nX-Recruiting:\x20/
SF:#/jobs\r\nAccept-Ranges:\x20bytes\r\nCache-
```

Screenshot 1

```
SF:uest\r\nConnection:\x20close\r\n\r\n")%r(HTTPOptions,
EA,"HTTP/1.1\x202
SF:04\x20No\x20Content\r\nAccess-Control-Allow-
Origin:\x20*\r\nAccess-Con
SF:trol-Allow-
Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Acces
SF:s-Control-Request-Headers\r\nContent-
Length:\x200\r\nDate:\x20Mon,\x202
SF:7\x20Apr\x202026\x2014:50:30\x20GMT\r\nConnection:
\x20close\r\n\r\n")%r
SF:
(RTSPRequest,EA,"HTTP/1.1\x20204\x20No\x20Content\r\n
Access-Control-Al
SF:low-Origin:\x20*\r\nAccess-Control-Allow-
Methods:\x20GET,HEAD,PUT,PATC
SF:H,POST,DELETE\r\nVary:\x20Access-Control-Request-
Headers\r\nContent-Len
SF:gth:\x200\r ↓ ate:\x20Mon,\x2027\x20Apr\x202026\x2
014:50:30\x20GMT\r\nC
SF:onnection:\x20close\r\n\r\n");
```

Screenshot 2

Detailed Findings

Immediate Actions:

- Remove sensitive files from public directories
- Secure or remove publicly accessible backup files
- Remove suspicious files from exposed locations

Medium-Term Actions:

- Enforce HTTPS across the application
- Implement missing security headers such as CSP and HSTS
- Secure cookies using Secure and HttpOnly attributes

Long-Term Improvements:

- Perform regular vulnerability assessments
- Monitor exposed directories and services
- Maintain updated application dependencies
- Conduct periodic security reviews

Conclusion:

- The assessment identified multiple security weaknesses, primarily related to exposed sensitive files, missing security configurations, and information disclosure issues.
- While no active exploitation was performed, the findings indicate that the application would benefit from stronger access controls, secure communication practices, and improved server hardening to reduce overall security risk and align with industry best practices.

Owasp Zap Scan Result Screenshots:

```
true GET http://localhost:3000/scripts.js
true GET http://localhost:3000/main.js
false GET https://angular.dev/best-practices/security Out of Scope
false GET https://www.cookiesandyou.com/ Out of Scope
false GET http://www.w3.org/2000/svg Out of Scope
false GET http://www.w3.org/1999/xhtml Out of Scope
false GET http://www.w3.org/1999/xlink Out of Scope
false GET http://www.w3.org/XML/1998/namespace Out of Scope
false GET http://www.w3.org/2000/xmlns/ Out of Scope
false GET http://www.w3.org/1998/Math/MathML Out of Scope
false GET https://owasp.org/ Out of Scope
false GET https://owasp-juice.shop/ Out of Scope
false GET https://socket.io/docs/v3/migrating-from-2-x-to-3-0/ Out of Scope
false GET https://www. leapis.com/oauth2/v1/userinfo?alt=json Out of Scope
false GET https://github.com/juice-shop/juice-shop Out of Scope
```

Screenshot 1

```
true GET http://localhost:3000/juice-shop/build/routes/assets/public/chunk-4MIYPPGW.js
true GET http://localhost:3000/juice-shop/build/routes/assets/public/chunk-LHKS7QUN.js
true GET http://localhost:3000/juice-shop/build/routes/assets/public/chunk-TWZW5B45.js
true GET http://localhost:3000/juice-shop/build/routes/assets/public/polyfills.js
true GET http://localhost:3000/juice-shop/build/routes/assets/public/scripts.js
true GET http://localhost:3000/juice-shop/build/routes/assets/public/main.js
true GET http://localhost:3000/ftp/
true GET http://localhost:3000/ftp/quarantine/juicy_malware_linux_arm64.url
true GET http://localhost:3000/ftp/quarantine/juicy_malware_linux_arm64.url
true GET http://localhost:3000/ftp/quarantine/juicy_malware_macos
```

Screenshot 2

Firefox Developer Edition Web-Dev Tools:

Status	Method	Domain	File	Initiator	Type	Transformed	Size	Headers	Cookies	Request	Response	Cache	Timings
200	GET	localhost:3000	/	document	html	cached	75 kB	GET http://localhost:3000/					
200	GET	localhost:3000	chunk-24E2L24.js	script	js	cached	1.38 kB						
200	GET	localhost:3000	chunk-T3PSK245.js	script	js	cached	11.23 kB						
200	GET	localhost:3000	chunk-4MIYPPGW.js	script	js	cached	380.6 kB						
200	GET	localhost:3000	chunk-LHKS7QUN.js	script	js	cached	236.0 kB						
200	GET	localhost:3000	chunk-TWZW5B45.js	script	js	cached	1.69 kB						
200	GET	localhost:3000	polyfills.js	script	js	cached	14.59 kB						
200	GET	localhost:3000	scripts.js	script	js	cached	20.70 kB						
200	GET	localhost:3000	main.js	script	js	cached	1.36 kB						
200	GET	localhost:3000	styles.css	stylesheet	css	cached	651.8 kB						
200	GET	localhost:3000	en.json	polyfills.js [xhr]	json	cached	33.17 kB						
200	GET	localhost:3000	/socket.io/?EIO=4&transport=polling&sid=PS8yp...	polyfills.js [xhr]	plain	326 B	36.8 kB						
200	GET	localhost:3000	application-version	polyfills.js [xhr]	json	cached	20.8 kB						
200	GET	localhost:3000	application-configuration	polyfills.js [xhr]	json	cached	21.77 kB						
200	GET	localhost:3000	/api/challenges/name=Score Board	polyfills.js [xhr]	json	cached	449 B						
200	GET	localhost:3000	languages	polyfills.js [xhr]	json	cached	4.24 kB						
200	GET	localhost:3000	application-version	polyfills.js [xhr]	json	cached	404 B						
200	GET	localhost:3000	application-configuration	polyfills.js [xhr]	json	cached	8.90 kB						
200	GET	localhost:3000	/api/challenges/name=Score Board	polyfills.js [xhr]	json	cached	835 B						
200	GET	localhost:3000	application-configuration	polyfills.js [xhr]	json	cached	8.90 kB						

Response Headers

```
⌚ Date: Tue, 28 Apr 2026 04:10:31 GMT
🏷️ ETag: W/"124fa-19dcf36ddle"
🔒 Feature-Policy: payment= self
⌚ Keep-Alive: timeout=5
🕒 Last-Modified: Mon, 27 Apr 2026 13:52:52 GMT
🔒 X-Content-Type-Options: nosniff
🔒 X-Frame-Options: SAMEORIGIN
🔒 X-Recruiting: #/jobs
📡 Request Headers (692 B)
🔒 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
🔒 Accept-Encoding: gzip, deflate, br, zstd
🔒 Accept-Language: en-US,en;q=0.9
🔒 Connection: keep-alive
🍪 Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=y1Qz8ZxNpnLM5WmgEKv8XakQ7DA6LcQG6yOIV9Pow1Tqzb2eRB34oE5mM
🏠 Host: localhost:3000
🕒 If-Modified-Since: Mon, 27 Apr 2026 13:52:52 GMT
🔒 If-None-Match: W/"124fa-19dcf36ddle"
🔒 Priority: u=0,i
🔒 Sec-Fetch-Dest: document
🔒 Sec-Fetch-Mode: navigate
🔒 Sec-Fetch-Site: none
🔒 Sec-Fetch-User: 71
🔒 Upgrade-Insecure-Requests: 1
👤 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0) Gecko/20100101 Firefox/151.0
```

Request Headers, Cookies